



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 10

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Contingency Planning (Business Continuity)

Objective of the session

- What business continuity management is
- What critical business functions (CBFs) are
- What a business impact analysis (BIA) is
- What a business continuity plan (BCP) is and how organizations use it to make sure a disruption does not put them out of business
- What role backups play in disaster recovery
- What steps to take to respond to security incidents What a disaster recovery plan (DRP) does
- What the primary steps to disaster recovery are

Business Continuity Management



- **Business continuity plan**—A business continuity plan (BCP) contains the actions needed to keep critical business processes running after a disruption.
- **Disaster recovery plan**—A disaster recovery plan (DRP) details the steps to recover from a disruption and restore the infrastructure necessary for normal business operations.
- **Crisis management**
- **Incident response management**
- **Risk management.**

Disruptions



- **Extreme weather**—Hurricanes Laura and Sally in 2020 are two examples of destructive weather events.
- **Criminal activity**—This might include the theft of credit card numbers or other customer data.
- **Civil unrest/terrorist acts**—Riots across the United States in 2020 caused disruptions to businesses of all types.
- **Operational**—For example, 268 million users worldwide had their Internet access shut off by government-imposed interruptions throughout 2020.
- **Application failure**—Three examples from 2020 are Microsoft Azure, Zoom, and Amazon Web Services failures.
- **Pandemic**—The most recent example of a worldwide pandemic is the COVID-19

Emerging Threats to Business Stability



- New technology
- Changes in the culture of the organization or environment
- Unauthorized use of technology
- Changes in regulations and laws
- Changes in business practices
 - Violation of virtualization barriers
 - Lack of access controls for outsourced resources
 - Reliability of cloud or virtualization services
 - Cloud service provider (CSP) lock-in
 - Insecure application program interfaces (APIs)
 - Malicious insiders
 - Account hijacking

Static Environments



- Supervisory Control and Data Acquisition (SCADA)—SCADA systems
- Embedded systems—Small computers that are contained in a larger device
- Mobile devices (Android and iOS)
- Mainframes—Large computers in large organization data centers
- Gaming consoles—Computers optimized to handle graphics applications efficiently
- Internet of Things (IoT) devices
- Vehicle systems

Key Terminology



- **Critical business function (CBF)**—A business function that is critical to an organization staying in business.
- **Business impact analysis (BIA)**—analysis of CBFs to determine what kinds of events could interrupt normal operation.
- **Maximum tolerable downtime (MTD)**—MTD is the most time a business can survive without a specific CBF
- **Recovery time objective (RTO)**—RTO is the timeframe for restoring a CBF
- **Recovery point objective (RPO)**—Maximum amount of tolerable data loss for each CBF.
- **Emergency operations center (EOC)**—Place where the recovery team will meet and work during a disruption.

Fault Tolerance



- **Redundant Array of Inexpensive Disks (RAID)**—A RAID comprises multiple disk drives that appear as a single disk drive but actually store multiple copies of data in case a disk drive in the array fails.
- **Clustering**—Clustering involves connecting two or more computers to act like a single computer.
- **Load balancing**—With load balancing two or more servers are used to respond to service requests.
- **Multiple servers or devices**—A more generalized implementation of load balancing simply makes multiple servers or network devices available that can respond to the same requests for service.
- **Outsourcing to the cloud**

Business Impact Analysis



- **Speed of Impact**

- Suppliers

- **Critical Dependencies**

- Information processing
- Personnel
- Communications
- Equipment
- Facilities
- Other organizational functions Vendors

- **Assessing the Impact of Downtime**

- People
- Systems
- Data
- Property

BCP Testing and Assurance



- Checklist Test
- Structured Walk-Through Test
- Simulation Test
- Parallel Test
- Full-Interruption Test

Backing Up Data and Applications

- Full backup - Copies everything to a backup media
- Differential backup – Backs up the differential changes since last full backup
- Incremental backup – Backs up only that day's changes after a full backup

Incident Handling

- Preparation
- Identification
- Notification
- Response
- Recovery and follow-up
- Documentation

Recovery from a Disaster (Common Issues)



- **Generators**—Generators must receive routine maintenance and should be run periodically to make sure they are ready to operate and capable of carrying the expected system load.
- **Safety of damaged site**—You must protect the primary (damaged) site from further damage or looting.
- **Reentry**—Arrange for qualified people to examine the damaged site and determine whether it is safe for humans to reenter and occupy the space.
- **Transportation of equipment and backups**—The plan must provide safe transportation of people, equipment, and backup data to and from the alternate site.
- **Communications and networks**—Traditional and cellular telephone service and network connectivity often fail in a crisis.

Interim or Alternate Processing Strategies



- An alternate processing center or **mirrored site** is always ready and under the organization's control.
- A **hot site** is one that can take over operations quickly. It has all the equipment and data already staged at the location.
- A **warm site** has some of the common IT, communications, power, and HVAC, but no IT equipment such as servers and communications.
- A **cold site** is an empty data center with HVAC and power and is the least expensive option.
- A **mobile site** is a trailer with necessary environmental utilities that can operate as a warm or a cold site.

Interim or Alternate Processing Strategies

FEATURE	HOT SITE	WARM SITE	COLD SITE	MOBILE SITE	MULTIPLE SITES
Cost	High	Medium	Low	Varies	No direct costs
Computer equipped	Yes	Yes	No	Yes (if warm)	Yes
Connectivity equipped	Yes	Yes	No	Yes (if warm)	Yes
Data equipped	Yes	No	No	No	Yes
Staffed	Yes	No	No	No	Yes
Typical lead time to readiness	Minutes to hours	Hours to days	Days to weeks	Hours to days	Moments to minutes

Assignment

- Complete and submit assessment.



Thank You